第三章 SQL注入漏洞与防护——实验分析报告

学号：_____ 姓名：_____ 完成日期：2026年04月30日

一、作业目标

完成本实验后，能够：

- 解释SQL注入的形成条件与根因。
- 在DVWA中观察和复现基础SQL注入现象。
- 区分普通SQL注入与盲注在证据层的差异。
- 比较Low与Medium在控制思路上的差异。
- 从参数化查询、错误处理和最小权限角度解释防护链条。

二、作业主线

核心主线： 输入 → 拼接 → 解析 → 执行 → 回显/行为差异 → 结构分离防护。
SQL注入的根因是**查询结构被污染**，而不是某几个字符“天生危险”。

三、实验环境与授权边界

- 实验环境：DVWA、本机浏览器、localhost/127.0.0.1
- 禁止行为：不对公网真实目标进行注入实验、不使用未授权系统、截图脱敏处理

四、作业任务

任务1：数据库与查询条件基础说明（3分）

1. 页面输入与数据库查询的关系
网页的登录、搜索、查询等功能，本质是用户输入条件 → 数据库查询 → 返回结果的业务流程。用户在前端输入的内容，会被后端程序接收并带入SQL语句中执行。

2. 最小业务链路
用户输入 → 后端接收 → SQL拼接 → 数据库执行 → 结果返回页面

3. 输入进入查询条件的方式
用户输入未经过安全处理，直接以字符串形式拼接到SQL查询语句中，成为SQL语句的一部分。

4. SQL注入的可能性来源
当输入可以改变原有SQL结构时，攻击者就能构造特殊输入，执行非预期操作，形成SQL注入。
示例：登录框输入 `’ OR 1=1#`，拼接后语句恒成立，实现越权访问。

任务2：DVWA SQL Injection Low 现象记录（4分）

1. 实验目标：DVWA SQL Injection（Low级别）页面，通过ID查询用户信息。

2. 普通输入与异常输入对比
• 普通输入：`1` → 返回ID=1的单条用户信息。
• 异常输入：`1’ OR 1=1#` → 返回所有用户信息。

3. 返回结果差异
正常输入仅返回单条数据；注入输入后返回全部数据，数据量与内容完全超出正常业务范围。

4. 为什么不像正常查询变化
正常业务逻辑不可能返回全部用户，现象证明输入改变了查询的结构，而不只是查询条件。

任务3：机制分析与差异比较（4.5分）

1. 完整执行链条
输入 → 字符串拼接 → 数据库解析SQL结构 → 执行恶意逻辑 → 回显结果/行为差异

2. 根因：结构被污染
危险字符本身无害，输入被拼入SQL语句、参与结构构造，导致原有查询逻辑被篡改，这才是根因。

3. Low与Medium差异
• Low：无任何过滤，输入直接拼接，完全可控。
• Medium：对单引号’进行转义或过滤，增加了注入难度，但未从根本上解决拼接问题。

4. 普通注入与盲注差异
• 普通SQL注入：页面直接回显查询结果，可直接看到数据。
• 盲注：页面不回显具体数据，仅返回“存在/不存在”“成功/失败”等状态，通过布尔或时间差异判断结果。

5. 强制判断题
1️⃣ SQL注入根因：**B. 输入进入了不该进入的查询结构**
理由：字符无危险，危险的是输入参与SQL结构构造。

2️⃣ 盲注与普通注入差异：**B. 证据形式不同**
理由：根因都是拼接导致结构污染，只是回显方式不同。

任务4：SQL注入防护清单与解释（3.5分）

防护措施	解决问题	控制层级	不能替代
参数化查询	分离数据与结构，从根因阻止注入	根因控制	不能替代权限控制
输入校验	过滤非法字符，缩小攻击面	暴露面控制	不能替代参数化查询
错误处理	关闭详细报错，避免泄露结构	暴露面控制	不能阻止注入执行
最小权限	限制数据库账户权限，降低危害	后果范围控制	不能防止注入发生

五、收口项

收口项1：SQL注入因果链/防护关系图

输入点 → 查询构造（拼接=根因） → 数据库解析/执行 → 结果/行为差异

↓（防护控制点）

参数化查询（阻断根因）

输入校验（减少恶意输入）

错误处理（隐藏信息）

最小权限（降低危害）

收口项2：学生自评表

- **最清楚的一点：** SQL注入根因是查询结构被污染，而非危险字符。
- **最容易混淆的一点：** 盲注与普通注入的差异，以及Low/Medium防护逻辑区别。
- **最需要教师复核：** 机制分析与防护措施对应关系。
- **重做优先修改：** 补充更多盲注与普通注入的对比实验证据。

收口项3：AI输出审核与人工复核记录

- 使用AI辅助：报告框架、术语解释、防护措施梳理。
- 人工复核保留：核心逻辑、实验现象、根因分析、判断题结论。
- 修正AI错误：AI曾混淆“过滤字符”与“结构分离”，已明确参数化查询才是根因防护。
- 结论确认：所有结论均对应实验现象与执行链条，证据一一匹配。

六、总结

SQL注入的本质是输入参与SQL结构构造，防护核心是用**参数化查询**分离数据与结构，配合输入校验、错误处理、最小权限形成完整防护链，从根因、暴露面、后果范围三层防御。

📌 **提交说明：** 本报告已按作业要求完整编写。可将此HTML文件“打印 → 另存为PDF”形成最终PDF，命名格式为“学号姓名SQL注入漏洞与防护.pdf”。打印前请手动填写学号、姓名。

✅ 实验现象、根因分析、防护链条清晰完整，符合DVWA SQL注入实验分析报告标准。

—— 实验分析报告·基于DVWA环境完成 ——